Microsoft 365 E7 Plan Security Controls

1. Identity and Access Hardening

Risk

Traditional MFA methods like SMS and voice and legacy authentication protocols are vulnerable to phishing and social engineering. In addition, permanent Global Administrator accounts increase the potential impact of compromised credentials.

Rollout

Remove standing Global Administrator privileges admins and instead use Privileged Identity Management (PIM) to provide just-in-time administrative access, with approval from a second administrator where appropriate.

Configure Conditional Access policies to require phishing-resistant MFA for all users and block legacy authentication protocols.

Microsoft 365 E7 includes Entra ID P2, providing access to PIM and Conditional Access at no extra cost.

Impact

This approach reduces the risk of credential theft leading to privileged account compromise and limits the time during which administrative privileges are available.

The main consideration is account recovery. Lost or unavailable authentication devices may require temporary access passes or alternative identity verification procedures. Administrators will also need to allow additional time for privileged access activation.

2. Threat Protection and Agent Governance

Risk

Malware, phishing campaigns and increasingly autonomous AI agents introduce additional security risks. Unmanaged agents may be deployed without proper assigned permissions, potentially exposing sensitive data.

Rollout

Apply the Microsoft Defender standard security preset to the general users and the strict preset to administrators and other high-risk users.

Review agent access requirements and apply appropriate Conditional Access policies and identity controls. Where agents use organisational data, ensure their access respects existing permissions and sensitivity labels.

Use Agent 365 capabilities to establish visibility and governance over the organisation's AI agents.

Defender preset policies and Agent 365 capabilities are included in the E7 plan.

Impact

These controls improve protection against common threats and provide better visibility into AI agent usage across the organisation.

Drawbacks include suspicious attachments requiring additional inspection before they can be opened. More restrictive security policies can also generate false positives.

3. Logging and Monitoring

Risk

Insufficient audit retention and monitoring can make it difficult to investigate security incidents, establish what happened and demonstrate compliance with regulatory requirements.

Rollout

Configure Microsoft Purview Audit retention policies to fit investigation and compliance requirements.

For example, retain critical audit events like administrative changes, mailbox rule creation, file access and permission changes for at least one year.

Configure Microsoft Defender alerts for high-risk activities and ensure relevant alerts are reviewed by the admins.

Verify agent activities are recorded in the available audit logs

Impact

Better audit coverage gives more information when investigating suspicious activity and responding to incidents. It also supports compliance reporting and internal audits.

Longer retention periods can make investigations more resource-intensive and portal searches across large date ranges may take longer.

4. Data Sharing Baseline

Risk

Default sharing settings can expose organisational information to unintended recipients. This becomes more important when deploying AI agents, as these tools may surface information that users already have permission to access but should not necessarily be able to see.

Rollout

Set the default sharing link type to Specific people.

Set default link permissions to View rather than Edit.

Restrict external sharing to new and existing guests where appropriate.

Set external sharing links to expire after 30 days.

Establish a regular review process for guest accounts and external access permissions.

These settings require no additional licences.

Impact

Restricting default sharing reduces the likelihood of accidental information exposure and makes external access easier to manage.

The main drawback is additional administration. Guest accounts and external permissions need to be reviewed regularly, and users may need assistance when sharing files with external partners.

5. Data Loss Prevention (DLP)

Risk

Sensitive information can leave the organisation through interfaces like SharePoint, OneDrive, Teams and AI interactions. Without consistent classification and DLP policies, the organisation has limited control over how sensitive information is shared or processed.

Rollout

Implement a classification and protection baseline using Microsoft Purview.

- Configure sensitivity labels for important document and email categories. Apply encryption and visual markings where appropriate.
- Create DLP policies to identify and restrict the sharing of sensitive information across Exchange, SharePoint, OneDrive and Teams.
- Extend DLP coverage to supported AI agent workloads, including prompts and responses.

Impact

A consistent classification improves the ability to identify and protect sensitive information, including information processed through AI workloads.

Tradeoffs and drawbacks include;

- Users need guidance on applying the correct sensitivity labels.
- DLP policies can interrupt business activities if they are too restrictive.
- Developing a useful label structure requires time and ongoing maintenance.